

Threat Actor Profile: TamperedChef

Threat Intelligence Profile — Malvertising & Infostealer Campaign

Published: 2026-05-29 | Profile ID: LBC-AP-2026-001 | TLP: AMBER

Prepared by: Lost Boys Cyber — Threat Intelligence Team

AI-ASSISTED REPORT — IMPORTANT DISCLOSURE

AI Generation: This profile was generated with AI assistance and is provided for informational purposes only. All attribution assessments, TTP mappings, IOCs, and detection rules must be independently validated by a qualified threat intelligence analyst before being acted upon, distributed externally, or used for any legal, regulatory, or operational decision.

Attribution Warning: Attribution in threat intelligence is probabilistic, not definitive. Confidence levels stated throughout reflect analytical assessment only — they do not constitute proof.

Currency: Threat actor behaviour and infrastructure evolves rapidly. This profile reflects intelligence available at time of publication (May 2026). Validate IOCs against current sources before operational use.

1. At a Glance

Attribute	Value
Primary Alias	TamperedChef
Other Names	EvilAI (partial campaign overlap)
Origin / Sponsorship	Unknown — assessed cybercriminal (financially motivated); possible multiple threat actors across clusters
Motivation	Financial — credential theft, adware monetisation, proxy deployment, remote access
Sophistication	Intermediate-to-Advanced (custom evasion, EV code signing via shell companies, AI-generated infrastructure)
Activity Status	Active
Active Since	February 2025 (first artefacts); large-scale operations from June 2025
Primary Targets	Windows endpoints — global; US, Germany, UK, France, Israel, Spain, India, Ireland. Sectors: Healthcare, Construction, Manufacturing
Signature Tools	Trojanised productivity apps (PDF editors, ZIP tools, GIF makers); obfuscated JavaScript backdoor; DPAPI credential harvester
Tracked Clusters	CL-CRI-1089 (criminal); CL-UNK-1090 (unknown); CL-UNK-1110 (unknown)
MITRE ATT&CK Group	Not formally assigned (G-series)
Assessment Confidence	Medium

2. Identity & Aliases

2.1 Primary Designation

TamperedChef is the primary name applied to this campaign, coined by Sophos MDR researchers who first publicly documented the infostealer payload and the malvertising delivery mechanism in September 2025. Unit 42 (Palo Alto Networks) adopted the same designation in their cluster-tracking research. The name references the campaign's defining tactic: tampered (trojanised) applications served as a poisoned course to unsuspecting users.

2.2 Known Designations by Vendor

Vendor	Designation
Sophos MDR	TamperedChef

Unit 42 / Palo Alto Networks	TamperedChef (CL-CRI-1089, CL-UNK-1090, CL-UNK-1110)
Microsoft WDSI	Trojan:Win64/TamperedChef!MSR
Truesec	TamperedChef (AppSuite PDF Editor campaign)
WithSecure Labs	TamperedChef
Twilight Cyber / GBHackers	TamperedChef
Partial campaign overlap	EvilAI (campaign-level alias used in some reporting)
MITRE ATT&CK Group	Not assigned
CISA	No formal designation at time of publication

2.3 Alias Notes

The "EvilAI" designation appears in some reporting as a campaign-level reference to a broader malvertising operation of which TamperedChef is a component. Analysts should treat TamperedChef as the specific malware/campaign label and EvilAI as a potentially wider umbrella. The Unit 42 cluster identifiers (CL-CRI-1089, CL-UNK-1090, CL-UNK-1110) represent internal tracking designations for distinct operational clusters within the broader TamperedChef activity set, which may involve different threat actor teams.

3. Attribution Assessment

3.1 Suspected Origin / Sponsorship

Assessment: Cybercriminal — financially motivated, likely multiple actor teams across clusters.

Confidence: Low-Medium

TamperedChef's tradecraft, infrastructure investment, and payload selection are consistent with organised cybercriminal operations rather than state-sponsored espionage. Payloads (infostealers, RATs, adware, proxy tools) are characteristic of financially motivated threat actors seeking credential monetisation, pay-per-install revenue, and remote access for follow-on compromise.

The campaign's use of shell companies across Ukraine, Malaysia, Israel, the United Kingdom, and the United States to acquire Extended Validation (EV) code-signing certificates suggests organised, multi-jurisdictional criminal infrastructure capable of sustained operational investment — Unit 42 estimated that operators behind a single cluster (CL-CRI-1089) spent over \$10,000 USD on code-signing certificates alone.

The CL-UNK-1090 cluster exhibits an unusual characteristic: the same actor group appears to own both the advertising agencies distributing the malicious content and the shell companies signing the malware. This integrated model suggests a more sophisticated criminal enterprise, possibly with legitimate advertising industry connections used as cover.

3.2 Attribution Evidence

Evidence Type	Detail	Confidence
Infrastructure	Shell companies in US, Ukraine, Malaysia, Israel, UK used to	Medium

	obtain EV code-signing certs. NameCheap domain registrations with privacy proxy.	
Financial motivation	Payloads (Lumma Stealer, Rhadamanthys, AsyncRAT, adware, proxy tools) are canonical cybercriminal tooling — no intelligence collection indicators.	High
Scale & investment	Over \$10,000 spent on code signing alone; 34 unique signing entities in one cluster; 4,000+ samples — consistent with organised criminal enterprise.	Medium
AI-generated infrastructure	Operators used generative AI to produce distribution websites at scale, suggesting technical sophistication and resource availability.	Medium
Multi-cluster structure	Three distinct operational clusters with different modes of operation suggest either multiple actor groups or a compartmentalised criminal organisation.	Low
No official attribution	No DOJ indictment, CISA advisory, or government attribution statement at time of writing.	N/A

3.3 Alternative Hypotheses

- State-sponsored with criminal cover: The campaign's broad victimology (healthcare, construction, manufacturing) could serve intelligence collection purposes under the cover of financially motivated activity. Assessed unlikely — payload selection (adware, proxy, infostealer) is inconsistent with strategic espionage priorities.
- Single threat actor: All three clusters may be operated by one team using different operational personas. Cannot be ruled out — code and certificate reuse analysis shows some overlaps, but the operational models differ significantly between CL-CRI-1089 and CL-UNK-1090.
- Crimeware-as-a-Service: TamperedChef infrastructure may be leased or licensed to multiple downstream actors who deploy their own payloads. This would explain the payload diversity across clusters. Plausible given the observed structural differences.

4. Background & History

4.1 Overview

TamperedChef is a sustained malvertising campaign first detected in artefact form around February 2025, with large-scale operations launching from June 26, 2025. The campaign's defining innovation is the "long

dormancy" technique: trojanised productivity applications are distributed via paid advertising, function normally for a pre-defined period (56 days in the initial campaign wave), then activate malicious capabilities in a co-ordinated mass activation event. This approach directly exploits the typical duration of digital advertising campaigns to avoid early detection.

The campaign has generated over 4,000 malware samples across 100+ unique variants, with three distinct operational clusters identified by Unit 42 researchers. By late 2025, TamperedChef had affected over 300 hosts across more than 100 customer environments in 19 countries, with evidence of compromise present across more than 50% of Palo Alto Networks' Managed Threat Hunting customer base — a scale described by researchers as rarely observed.

The operation is notable for its sophisticated abuse of trust mechanisms: legitimate EV code-signing certificates, functional (if trojanised) applications, and AI-generated distribution websites that pass casual inspection. The August 21, 2025 mass activation event, in which applications that had been dormant for approximately 56 days simultaneously activated across thousands of endpoints, represents a significant operational security (OpSec) and detection challenge.

4.2 Timeline of Significant Activity

Date	Event	Significance
Feb 2025	Earliest TamperedChef artefacts observed in the wild	Initial development/testing phase; limited distribution
Jun 26, 2025	Large-scale campaign launch — AppSuite PDF Editor distributed via Google Ads	Mass distribution begins; >100 fake sites registered on NameCheap
Aug 21, 2025	Co-ordinated mass activation across all dormant installations	56-day dormancy timer expires; malicious capabilities activate simultaneously across thousands of endpoints
Sep 2025	Sophos MDR identifies and publicly discloses TamperedChef campaign	First major public disclosure; 300+ hosts affected across 100+ customer environments in 19 countries
Nov 2025	The Hacker News and wider press coverage of ongoing global campaign	Campaign confirmed still active; fake software installers remain in circulation
Nov–Dec 2025	Unit 42 publishes cluster tracking research (CL-CRI-1089, CL-UNK-1090, CL-UNK-1110)	4,000+ samples catalogued; 34 signing entities traced in CL-CRI-1089; certificate and code reuse methodology published
Q4 2025	CIS Top 10 Malware listing	TamperedChef achieves notable prevalence ranking in quarterly malware statistics
2026	Campaign assessed ongoing	Infrastructure and new variants remain active; multiple productivity app lures in circulation

4.3 Notable Campaigns

AppSuite PDF Editor Campaign — June–August 2025: The initial and best-documented TamperedChef campaign distributed a trojanised PDF editing application called AppSuite PDF Editor via Google Ads. Users searching for PDF tools on Bing and Google were served malicious ads directing them to convincing NameCheap-hosted sites. The installer was signed with valid EV certificates. After a 56-day dormancy period, applications activated on August 21, 2025, deploying a scheduled task (task.xml) and obfuscated JavaScript backdoor, followed by credential-stealing payloads. Sophos MDR documented over 300 victims across 19 countries.

Productivity App Expansion — Late 2025: Beyond PDF editors, Unit 42 documented TamperedChef variants masquerading as ZIP file extractors, calendar applications, and GIF image-making tools. This expansion demonstrates iterative adaptation of the core delivery mechanism across multiple application categories, with over 100 unique variants catalogued. The three operational clusters (CL-CRI-1089, CL-UNK-1090, CL-UNK-1110) operated with distinct signing entity networks and payload preferences.

5. Objectives & Targeting

5.1 Strategic Motivation

TamperedChef is assessed as financially motivated. Primary objectives are credential theft (browser-stored passwords, cookies, authentication tokens) for subsequent account takeover and sale on criminal marketplaces, adware monetisation (browser hijacking, search redirection), and deployment of proxy tooling and RATs for remote access sales or follow-on compromise. The multi-payload delivery model (infostealers in one cluster, adware+proxy in another) suggests either multiple actors with different monetisation strategies sharing the delivery infrastructure, or a single actor offering access-as-a-service to downstream clients.

5.2 Targeting Profile

Sectors: Healthcare, construction, and manufacturing are the most heavily affected sectors based on Sophos telemetry. This likely reflects opportunistic targeting — these sectors have large Windows endpoint estates and employees who regularly search for productivity software — rather than strategic sector selection.

Geographies: The United States is the primary victim geography, with significant concentrations also identified in Germany (~15% of victims), the United Kingdom (~14%), France (~9%), Israel, Spain, India, and Ireland. The campaign is global in distribution; geographic weighting likely reflects advertising spend allocation and search engine market share.

Attribute	Detail
Organisation Size	All sizes — enterprise and SMB both affected; no evidence of deliberate size selection
Technology Environment	Windows-centric (Windows 10/11 endpoints); browser credential stores targeted (Chrome, Firefox, Edge)
Specific Technologies Targeted	Browser credential stores (DPAPI-encrypted); Windows Task Scheduler; Windows Registry
Access Brokers	Unknown — possible downstream sale of credentials or remote access; CL-UNK-1090 structure suggests potential access brokerage

	model
Initial Targeting Vector	Search-engine advertising (Google Ads, Bing Ads) targeting users searching for productivity software

5.3 Target Selection Method

TamperedChef uses search-engine malvertising as its primary selection mechanism — users self-select by searching for specific software categories (PDF editors, ZIP tools, etc.). The actor does not conduct targeted spearphishing or sector-specific reconnaissance. Victim selection is effectively driven by search behaviour, meaning any organisation whose employees search for productivity software using an unmanaged or insufficiently protected endpoint is at risk. The use of Google Ads and Bing Ads for distribution is calculated: paid search results appear above organic results, reach users with genuine intent to install software, and carry implicit trust from the search engine brand.

6. Tactics, Techniques & Procedures (TTPs)

6.1 MITRE ATT&CK Coverage

Tactic	Technique	Observed	Freq	Notes
Resource Development	T1583.001 — Acquire Domains	Yes	High	NameCheap; privacy proxy; AI-generated site content
Resource Development	T1588.003 — Obtain Code Signing Certs	Yes	High	EV certs via shell companies; est. \$10k+ spend per cluster
Resource Development	T1583.008 — Malvertising	Yes	High	Google Ads, Bing Ads; primary distribution mechanism
Initial Access	T1204.002 — User Execution: Malicious File	Yes	High	User installs trojanised app after clicking malvertising link
Execution	T1059.007 — JavaScript	Yes	High	Heavily obfuscated JS backdoor dropped via scheduled task
Execution	T1053.005 — Scheduled Task	Yes	High	task.xml creates task running JS every 24h with random delay

Persistence	T1053.005 — Scheduled Task	Yes	High	Primary persistence mechanism (task.xml)
Persistence	T1547.001 — Registry Run Keys	Yes	High	HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\PDFEdit
Defence Evasion	T1553.002 — Code Signing	Yes	High	Legitimate EV certificates; bypasses most AV/EDR trust checks
Defence Evasion	T1036.005 — Masquerading: Match Legit Name/Location	Yes	High	App functions normally; task names mimic legit Windows tasks
Defence Evasion	T1497 — Virtualization/Sandbox Evasion	Yes	High	56-day dormancy evades sandbox and trial-period security scanning
Defence Evasion	T1027 — Obfuscated Files or Information	Yes	High	Heavily obfuscated JavaScript payload
Credential Access	T1555.003 — Credentials from Web Browsers	Yes	High	DPAPI abuse; browser processes force-terminated then credential stores decrypted
Credential Access	T1539 — Steal Web Session Cookie	Yes	High	Authentication tokens and cookies extracted alongside passwords
Collection	T1005 — Data from Local System	Yes	High	Stored credentials, cookies, auth tokens
Command & Control	T1071.001 — Web Protocols	Yes	High	HTTP/S C2; api.mxpanel.com noted as actor-abused endpoint
Exfiltration	T1041 — Exfiltration Over C2 Channel	Yes	High	Credentials exfiltrated over C2 channel

Impact	T1176 — Browser Extensions	Suspected	Med	Adware / browser hijacker payloads in CL-CRI-1089 cluster
--------	----------------------------	-----------	-----	---

6.2 Initial Access

TamperedChef's initial access is exclusively through malvertising. Users searching for productivity software (PDF editors, ZIP extractors, GIF makers, calendar apps) on Google or Bing are served paid advertisements that appear above legitimate results. Clicking the ad redirects to convincing, AI-generated websites hosted on NameCheap domains. The download is a trojanised installer signed with a valid EV code-signing certificate, which passes Windows SmartScreen and most AV checks. The application installs and functions normally — a deliberate choice to avoid user suspicion and early incident reports.

Vector	Detail	ATT&CK	Frequency
Search ad malvertising	Google Ads/Bing Ads served to users searching for productivity software; AI-generated landing sites on NameCheap domains	T1583.008	High
Trojanised installer	Signed installer (.exe) appears legitimate; installs functional application + hidden malicious components	T1204.002 / T1553.002	High
Fake product manual sites	Some variants distributed via fake product manual / driver download sites surfaced in search results	T1583.001	Medium

6.3 Persistence

Two persistence mechanisms are documented. The primary mechanism is a Windows Scheduled Task created by dropping task.xml to disk, configuring a task that executes the obfuscated JavaScript backdoor every 24 hours with a randomised delay (anti-detection timing jitter). The secondary mechanism is a Registry Run key at HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\PDFEdit, which ensures execution at user logon. Task naming conventions deliberately mimic legitimate Windows maintenance tasks to evade casual inspection.

6.4 Defence Evasion

TamperedChef employs several layered evasion techniques. The 56-day dormancy period is the most operationally significant: because the application functions correctly and displays no malicious behaviour during this period, it evades sandbox analysis (typically limited to minutes), trial security scans, and initial incident investigation. EV code-signing certificates obtained through shell companies provide trust signals that bypass SmartScreen and most AV products. The JavaScript payload is heavily obfuscated. Scheduled task naming mimics legitimate Windows system tasks. AI-generated distribution websites are structurally unique across deployments, frustrating URL-pattern blocking.

6.5 Credential Access

Upon activation, the JavaScript backdoor force-terminates all running browser processes (Chrome, Firefox, Edge) and then abuses the Windows Data Protection API (DPAPI) to decrypt browser credential stores. DPAPI decryption is performed in the context of the logged-in user, meaning no privilege escalation is required. Extracted data includes saved passwords, session cookies, and authentication tokens — sufficient to perform account takeover without requiring the plaintext password.

6.6 Exfiltration

Credentials, cookies, and tokens are exfiltrated over HTTPS to actor-controlled C2 infrastructure. The C2 channel uses web protocols (T1071.001), with `api.mxpanel.com` documented as one actor-abused endpoint (note: `mxpanel.com` is a legitimate analytics service — the actor abuses its API structure as a C2 proxy, a common evasion technique against proxy-based filtering). The C2 also delivers second-stage payloads (info stealers, RATs, proxy tools) and receives operator commands.

7. Toolset

7.1 Custom / Campaign-Specific Tools

Tool Name	Type	Purpose	First Seen	Notes
TamperedChef installer framework	Trojanised installer	Delivery and dormancy management; wraps legitimate app with hidden payload	Feb 2025	EV-signed; functional app maintained during dormancy
Obfuscated JS backdoor	JavaScript backdoor	Post-activation C2, DPAPI credential theft, payload staging	Jun 2025	Dropped via <code>task.xml</code> scheduled task; runs every 24h
<code>task.xml</code> / persistence module	Persistence dropper	Creates scheduled task and registry Run key	Jun 2025	Task names mimic legitimate Windows maintenance tasks

7.2 Commodity / Second-Stage Payloads

Tool Name	Type	Purpose	Notes
Lumma Stealer	Info stealer	Credential and crypto wallet theft	Delivered as second-stage by CL-CRI-1089 cluster
Rhadamanthys	Info stealer	Credential and data theft	Delivered as second-stage; sophisticated multi-module stealer

AsyncRAT	Remote Access Trojan	Full remote access to compromised host	Enables persistent operator access post-compromise
Emmenhtal	Loader	Second-stage loader for additional payloads	Used as intermediate stage before final payload deployment
XWorm	RAT / Stealer	Remote access and data theft hybrid	Seen in some cluster variants
Adware / browser hijacker	Adware	Search redirection, ad injection, browser takeover	Primary payload in some CL-CRI-1089 sub-clusters
Proxy tool	Proxy / traffic redirector	Route actor traffic through victim hosts	Seen in CL-CRI-1089; monetised via residential proxy networks

8. Infrastructure Profile

8.1 Hosting Preferences

Attribute	Observed Pattern
Domain Registrar	NameCheap — primary registrar for distribution domains; privacy proxy used to obscure WHOIS registrant data
TLD Preferences	.com primary; patterns designed to resemble legitimate software vendor or product sites
Domain Naming Convention	Mimics legitimate software product names; includes terms like "pdf", "editor", "tools", "suite", "pro" — designed to appear in search results alongside legitimate results
Code Signing	Extended Validation (EV) certificates obtained through shell companies in US, Ukraine, Malaysia, Israel, UK. NamedEntities: Stratus Core Digital LLC, DataX Engine LLC (US), plus ~32 others in CL-CRI-1089. Estimated \$10,000+ per cluster on certificate acquisition.
Certificate Use	EV certificates — highest trust level; bypasses Windows SmartScreen and most AV trust heuristics
AI-Generated Sites	Distribution websites generated using AI tools — visually similar but structurally unique across deployments, frustrating pattern-based blocking
Infrastructure Rotation	New signing entities and domains registered per

	campaign wave; certificate diversity across 34+ entities in CL-CRI-1089 alone
C2 Infrastructure	Actor-controlled HTTPS endpoints; legitimate service API abuse (mxpanel.com-style) for traffic blending

8.2 Shell Company Infrastructure

A defining characteristic of TamperedChef is the industrialised acquisition of EV code-signing certificates through a network of shell companies across multiple jurisdictions. Unit 42 traced 34 unique signing entities to the CL-CRI-1089 cluster alone through corporate structure analysis, certificate sharing, and code reuse patterns. The CL-UNK-1090 cluster took a more vertically integrated approach — the same entity group owned both the advertising agencies distributing the malware and the shell companies obtaining the signing certificates.

Known signing entities (partial list from public reporting): Stratus Core Digital LLC (US), DataX Engine LLC (US), plus entities in Ukraine, Malaysia, Israel, and the United Kingdom. These companies are assessed as purpose-built for certificate acquisition with no legitimate business operations.

9. Indicators of Compromise

⚠️ IOC Currency Warning: TamperedChef infrastructure rotates aggressively. All IOCs below must be validated against current threat intelligence sources (VirusTotal, URLhaus, Unit42/Sophos threat feeds) before production ingestion. Historical IOCs may be expired, sinkholed, or reassigned to legitimate users. Treat all IOCs as Medium confidence absent independent corroboration.

9.1 Network IOCs (Historical / Representative)

```
# C2 Endpoint (documented – validate currency before blocking)
api.mxpanel.com [C2 channel – legitimate service API abused; context-dependent blocking advised]

# Distribution domain pattern (NameCheap – indicative naming convention):
*.appsuitepdfeditor[.]com [distribution – AppSuite PDF Editor campaign]
# Note: TamperedChef uses hundreds of unique domains per campaign wave
# Refer to Unit42 threat feed and Sophos IOC lists for current domain inventory
```

9.2 Host IOCs

```
# Scheduled Task artefact
task.xml [dropped to disk on activation; creates scheduled task]

# Registry Run Key (persistence)
HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\PDFEdit

# Code signing certificate entities (shell companies – flag if encountered)
Stratus Core Digital LLC
DataX Engine LLC
# Additional signing entities: refer to Unit42 CL-CRI-1089 research for full list

# File hashes: refer to Sophos, Unit42, MalwareBazaar for current sample hashes
# Microsoft WDSI detection: Trojan:Win64/TamperedChef!MSR
```

9.3 IOC Confidence Ratings

IOC	Type	Confidence	Currency	Notes
api.mxpanel.com	Domain	Low	Historical	Legitimate service abused — blocking may cause FPs; monitor in context
HKCU\...\Run\PDFEdit	Registry Key	High	Active	High-fidelity persistence artefact; validate against legitimate software in environment
task.xml (scheduled task drop)	File/Artefact	High	Active	Abnormal task XML drop to user-writable location is high-fidelity
Stratus Core Digital LLC cert	Code Sign Cert	High	Historical	Shell company; no legitimate software uses this certificate
DataX Engine LLC cert	Code Sign Cert	High	Historical	Shell company; no legitimate software uses this certificate
appsuitepdfeditor[.com domains	Domain pattern	Medium	Historical	Validate against current domain lists; campaign domains rotate

10. Detection

10.1 Sigma Rule — TamperedChef Scheduled Task Persistence

```

title: TamperedChef – Scheduled Task Created from task.xml Drop
id: a7f3c2e1-8b4d-4a9f-b6c2-3d1e2f4a5b6c
status: experimental
description: >
  Detects creation of a Windows Scheduled Task from a dropped task.xml file,
  characteristic of TamperedChef post-activation persistence mechanism.
references:
  - https://www.sophos.com/en-us/blog/tamperedchef-serves-bad-ads-with-infostealers-as-the-main-course
  - https://unit42.paloaltonetworks.com/tracking-tampered-chef-clusters/
author: Lost Boys Cyber – Threat Intelligence
date: 2026-05-29
tags:
  - attack.persistence
  - attack.t1053.005

```

```

- attack.defense_evasion
logsource:
  product: windows
  service: security
detection:
  selection:
    EventID: 4698
  filter_legit:
    SubjectUserName|endswith: "$"
  filter_schtasks:
    ProcessName|endswith: "schtasks.exe"
    SubjectUserName: "SYSTEM"
  condition: selection and not 1 of filter_*
falsepositives:
  - Legitimate software installers creating scheduled tasks; validate against software inventory
  - IT automation tools (SCCM, Intune, Ansible)
level: medium

```

10.2 Sigma Rule — TamperedChef Registry Persistence

```

title: TamperedChef – Suspicious Registry Run Key PDFEdit
id: b8e4d1f2-9c5a-4b8e-c7d3-4e2f3a5b6c7d
status: experimental
description: >
  Detects creation of a Registry Run key named PDFEdit – characteristic persistence artefact of the TamperedChef infostealer campaign.
references:
  - https://www.sophos.com/en-us/blog/tamperedchef-serves-bad-ads-with-infostealers-as-the-main-course
author: Lost Boys Cyber – Threat Intelligence
date: 2026-05-29
tags:
  - attack.persistence
  - attack.t1547.001
logsource:
  product: windows
  category: registry_set
detection:
  selection:
    TargetObject|contains: "\\CurrentVersion\\Run"
    TargetObject|endswith: "\\PDFEdit"
  condition: selection
falsepositives:
  - Verify against installed legitimate PDF editing software in environment
level: high

```

10.3 Sigma Rule — DPAPI Browser Credential Theft

```

title: TamperedChef – Browser Forceful Termination followed by DPAPI Access
id: c9f5e2a3-0d6b-4c9f-d8e4-5f3a4b6c7d8e
status: experimental
description: >
  Detects non-browser processes accessing DPAPI-protected browser credential stores following browser process termination – consistent with TamperedChef credential harvesting behaviour.
references:
  - https://www.sophos.com/en-us/blog/tamperedchef-serves-bad-ads-with-infostealers-as-the-main-course
author: Lost Boys Cyber – Threat Intelligence
date: 2026-05-29
tags:

```

```

- attack.credential_access
- attack.t1555.003
logsource:
  product: windows
  category: process_access
detection:
  selection:
    TargetImage|contains:
      - "\Chrome\User Data"
      - "\Firefox\Profiles"
      - "\Edge\User Data"
    GrantedAccess: "0x1fffff"
  filter_browsers:
    SourceImage|endswith:
      - "\chrome.exe"
      - "\firefox.exe"
      - "\msedge.exe"
  condition: selection and not filter_browsers
falsepositives:
  - Legitimate backup or password manager software; validate SourceImage
level: high

```

10.4 KQL — Microsoft Defender for Endpoint

```

// TamperedChef: Registry Run Key Persistence Detection
DeviceRegistryEvents
| where Timestamp > ago(30d)
| where ActionType == "RegistryValueSet"
| where RegistryKey has "CurrentVersion\\Run"
| where RegistryValueName == "PDFEdit"
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName,
  RegistryKey, RegistryValueName, RegistryValueData
| order by Timestamp desc

// TamperedChef: Scheduled Task Creation from Non-Standard Process
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName == "schtasks.exe"
| where ProcessCommandLine contains "task.xml"
| where InitiatingProcessFileName !in ("setup.exe", "install.exe", "msiexec.exe")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName,
  ProcessCommandLine
| order by Timestamp desc

// TamperedChef: JavaScript Execution via Scheduled Task (wscript/cscript)
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName in~ ("wscript.exe", "cscript.exe")
| where InitiatingProcessFileName == "taskeng.exe"
  or InitiatingProcessParentFileName == "svchost.exe"
| where ProcessCommandLine has_any (".js", ".vbs")
| project Timestamp, DeviceName, AccountName, ProcessCommandLine,
  InitiatingProcessFileName
| order by Timestamp desc

```

10.5 YARA Rule — TamperedChef Installer

```

rule TamperedChef_Trojanised_Installer {
  meta:
    description = "Detects characteristics of TamperedChef trojanised
productivity app installers"
    author      = "Lost Boys Cyber – Threat Intelligence"

```

```

        date      = "2026-05-29"
        reference  = "https://unit42.paloaltonetworks.com/tracking-tampered-chef-
clusters/"
        actor      = "TamperedChef"
        severity    = "high"
    strings:
        $task_xml  = "task.xml" ascii wide
        $pdf_edit   = "PDFEdit" ascii wide
        $dpapi      = "CryptUnprotectData" ascii wide
        $run_key    = "CurrentVersion\\Run" ascii wide
        $js_sched   = "taskschd.msc" ascii wide nocase
        // Shell company cert subject strings (validate against current list)
        $cert1      = "Stratus Core Digital" ascii wide
        $cert2      = "DataX Engine" ascii wide
    condition:
        uint16(0) == 0x5A4D and
        filesize < 100MB and
        (
            ($task_xml and $run_key) or
            ($dpapi and $pdf_edit) or
            (1 of ($cert*) and $task_xml)
        )
}

```

11. Threat Hunting

Recommended lookback: minimum 90 days. Given the 56-day dormancy period, a 90-day lookback is required to capture pre-activation installation artefacts. 6-month lookback recommended if TamperedChef exposure is suspected.

11.1 Hunt: Scheduled Task Created by Non-Standard Process

Hypothesis: If TamperedChef has activated on a host, a scheduled task will have been created by a process other than legitimate system management tooling, referencing a .js or task.xml payload.

```

// MDE – Scheduled tasks created by unusual processes
DeviceProcessEvents
| where Timestamp > ago(90d)
| where FileName == "schtasks.exe"
| where ProcessCommandLine has_any (".js", "task.xml", "/xml")
| where InitiatingProcessFileName !in~ (
    "svchost.exe", "services.exe", "msiexec.exe",
    "setup.exe", "install.exe", "TaskSchedulerHelper.dll")
| summarize count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp),
    Commands=make_set(ProcessCommandLine)
    by DeviceName, InitiatingProcessFileName
| order by LastSeen desc

```

11.2 Hunt: Registry Run Key PDFEdit

Hypothesis: If TamperedChef persisted via registry, the PDFEdit Run key will be present in device registry event logs or can be found via live response.

```

// MDE – TamperedChef Registry Run Key
DeviceRegistryEvents
| where Timestamp > ago(90d)
| where RegistryKey has "CurrentVersion\\Run"
| where RegistryValueName has_any ("PDFEdit", "AppSuite", "PdfTool")
| project Timestamp, DeviceName, AccountName,
    RegistryKey, RegistryValueName, RegistryValueData,
    InitiatingProcessFileName

```

```
| order by Timestamp desc
```

11.3 Hunt: Signed Binary from Known Shell Companies

Hypothesis: If a TamperedChef installer was executed, the signing certificate issuer will reference one of the known shell companies. This hunt should be run against software inventory and process event logs.

```
// MDE – Processes signed by known TamperedChef shell companies
DeviceProcessEvents
| where Timestamp > ago(90d)
| where ProcessVersionInfoCompanyName has_any (
    "Stratus Core Digital", "DataX Engine")
| project Timestamp, DeviceName, AccountName, FileName,
    ProcessVersionInfoCompanyName, ProcessCommandLine,
    SHA256
| order by Timestamp desc
```

11.4 Hunt: DPAPI Credential Theft Pattern

Hypothesis: If TamperedChef activated and harvested credentials, a non-browser process will have accessed browser credential stores using DPAPI in the context of the user session.

```
// MDE – Non-browser access to browser credential directories
DeviceFileEvents
| where Timestamp > ago(90d)
| where FolderPath has_any (
    "Chrome\\User Data\\Default\\Login Data",
    "Firefox\\Profiles",
    "Edge\\User Data\\Default\\Login Data")
| where InitiatingProcessFileName !in~ (
    "chrome.exe", "firefox.exe", "msedge.exe",
    "GoogleUpdate.exe", "MicrosoftEdgeUpdate.exe")
| project Timestamp, DeviceName, AccountName, FolderPath,
    FileName, InitiatingProcessFileName, InitiatingProcessCommandLine
| order by Timestamp desc
```

11.5 Hunt: Software Installed via Ad-Served Domain

Hypothesis: TamperedChef installers are downloaded from malvertising landing sites on NameCheap domains. DNS query logs or proxy logs from 90+ days ago may show the download request. This is particularly useful for identifying infected hosts that activated before detection tooling was in place.

Search proxy/DNS logs for downloads (GET requests, .exe files) from domains containing "pdf", "editor", "suite", "tool", "pro" patterns hosted on NameCheap ASN (AS22612) or similar low-cost hosting. Correlate with host software installation events in the same time window.

12. Recommended Defensive Posture

12.1 Priority Hardening Actions

- Implement application allowlisting or software restriction policies — TamperedChef relies entirely on user execution of an unsigned (from an organisational CA perspective) third-party installer. Application control that restricts execution to approved software catalogues would block initial compromise.
- Deploy Attack Surface Reduction (ASR) rules — specifically, block JavaScript and VBScript execution via wscript.exe/cscript.exe from locations outside sanctioned directories, and block persistence via Run key modifications from non-administrative processes.

- Enable Windows Defender SmartScreen Application Guard or equivalent — while EV certificates bypass standard SmartScreen, Application Guard provides additional sandboxing for downloaded executables.
- Review and restrict DPAPI access — consider monitoring for CryptUnprotectData calls from non-browser processes against browser credential store paths.
- Implement DNS filtering / web proxy for software download sites — categorise and block file hosting on known-bad infrastructure patterns; require software downloads to go through approved distribution channels.
- Enforce software procurement controls — educate users that all software must be obtained through IT-approved channels; malvertising specifically exploits the behaviour of searching for and installing software independently.
- Deploy browser password manager controls — consider disabling browser-native credential storage in favour of an enterprise password manager, which would eliminate the DPAPI credential theft attack surface.
- Enable Scheduled Task auditing (EventID 4698) and alert on task creation from non-standard parent processes — this provides the highest-fidelity post-activation detection signal.

12.2 Detection Priorities

- Highest priority: Scheduled Task creation (EventID 4698) from non-standard parent processes referencing .js payloads or task.xml — this is the primary post-activation artefact and is highly distinctive.
- High priority: Registry Run key writes to HKCU\...\Run\PDFEdit (or similar PDF/tool-named keys by non-installer processes) — secondary persistence artefact, lower false positive rate when combined with process context.
- High priority: Code signing certificate entity monitoring — block or alert on execution of binaries signed by known TamperedChef shell companies (Stratus Core Digital LLC, DataX Engine LLC, etc.).
- Medium priority: Non-browser process access to browser credential store files — useful for detecting activated TamperedChef instances and other infostealer activity.
- Medium priority: wscript.exe/cscript.exe spawned by taskeng.exe or svchost.exe (scheduled task host) with .js arguments — detects the recurring JS backdoor execution pattern.

12.3 Intelligence Collection Priorities

- Current TamperedChef domain inventory from Sophos, Unit42, and URLhaus feeds — the campaign's domain infrastructure is its highest-volume IOC type and rotates frequently.
- Updated code-signing entity list — Unit42's certificate and code reuse research identified 34 entities in CL-CRI-1089; monitoring for new signing entities following the same corporate structure pattern would provide early warning of new campaign waves.
- Malware sample hashes from MalwareBazaar and VirusTotal for YARA/EDR rule tuning — 4,000+ samples exist; current hash coverage is critical for initial execution blocking.
- Engagement with sector ISAC (Healthcare-ISAC, FS-ISAC) for victim notification intelligence — TamperedChef's healthcare sector concentration makes ISAC intelligence sharing particularly valuable.

13. Appendix — Related Intelligence

Item	Type	Relevance
------	------	-----------

Lumma Stealer	Malware Family	Delivered as second-stage payload by TamperedChef CL-CRI-1089 cluster
Rhadamanthys Stealer	Malware Family	Second-stage payload; sophisticated multi-module credential stealer
AsyncRAT	Malware Family	Remote access capability delivered post-TamperedChef activation
Emmenhtal Loader	Malware Family	Intermediate loader used in some TamperedChef infection chains
XWorm	Malware Family	RAT/stealer hybrid observed in TamperedChef cluster variants
T1583.008 Malvertising	ATT&CK Technique	Core delivery mechanism — see MITRE ATT&CK for related actor activity
T1553.002 Code Signing	ATT&CK Technique	EV certificate abuse is a high-investment, high-trust evasion mechanism shared with other sophisticated actors
Search Engine Malvertising (SEMalvertising)	Threat Category	TamperedChef is part of a broader trend of malvertising via paid search; related campaigns include FakeBat, BATLOADER, and others

14. References

- [1] Sophos MDR. "TamperedChef serves bad ads, with info stealers as the main course." <https://www.sophos.com/en-us/blog/tamperedchef-serves-bad-ads-with-info-stealers-as-the-main-course>
- [2] Unit 42 / Palo Alto Networks. "Tracking TamperedChef Clusters via Certificate and Code Reuse." <https://unit42.paloaltonetworks.com/tracking-tampered-chef-clusters/>
- [3] TrueSec. "Malicious AppSuite PDF Editor Spreads TamperedChef Malware." <https://www.truesec.com/hub/blog/tamperedchef-the-bad-pdf-editor>
- [4] WithSecure Labs. "TamperedChef: Malvertising to Credential Theft." <https://labs.withsecure.com/publications/tamperedchef>
- [5] BleepingComputer. "TamperedChef Info Stealer Delivered Through Fraudulent PDF Editor." <https://www.bleepingcomputer.com/news/security/tamperedchef-info-stealer-delivered-through-fraudulent-pdf-editor/>
- [6] The Hacker News. "TamperedChef Malware Spreads via Fake Software Installers in Ongoing Global Campaign." <https://thehackernews.com/2025/11/tamperedchef-malware-spreads-via-fake.html>

- [7] CyberSecurityNews. "TamperedChef Malware Uses Signed Productivity Apps to Deliver Stealers and RATs." <https://cybersecuritynews.com/tamperedchef-malware-uses-signed-productivity-apps/>
- [8] Hive Pro. "TamperedChef: A High-Severity Multi-Stage Infostealer Operation." <https://hivepro.com/threat-advisory/tamperedchef-a-high-severity-multi-stage-infostealer-operation/>
- [9] Microsoft Security Intelligence. "Trojan:Win64/TamperedChef!MSR." <https://www.microsoft.com/en-us/wdsi/threats/malware-encyclopedia-description?Name=Trojan:Win64/TamperedChef!MSR>
- [10] CIS Security. "Top 10 Malware Q4 2025." <https://www.cisecurity.org/insights/blog/top-10-malware-q4-2025>
- [11] MITRE ATT&CK. "Malvertising — T1583.008." <https://attack.mitre.org/techniques/T1583/008/>
- [12] MITRE ATT&CK. "Subvert Trust Controls: Code Signing — T1553.002." <https://attack.mitre.org/techniques/T1553/002/>